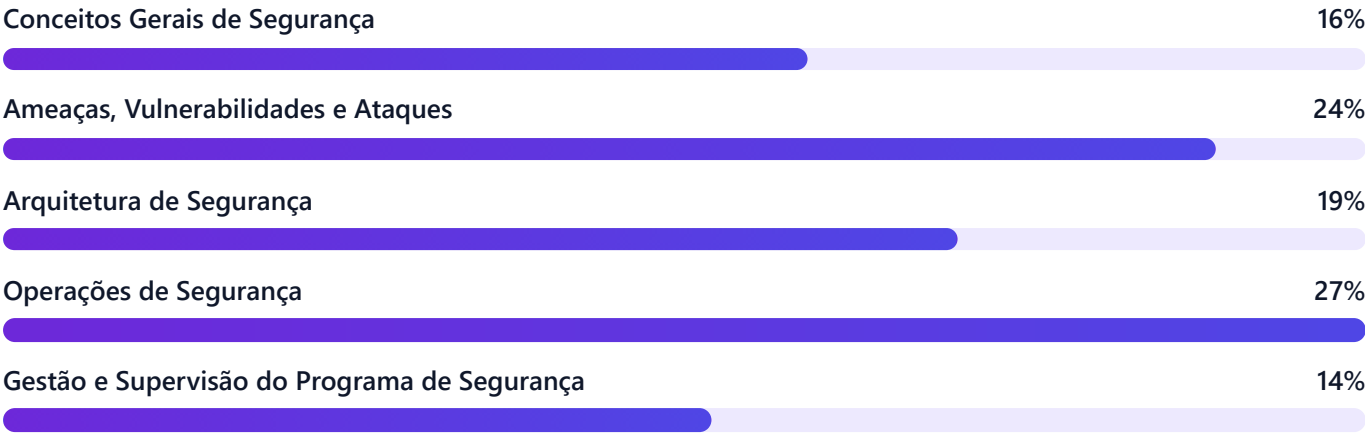
Strecht Simulados

Resumo de bolso CompTIA Security+ SY0-801

Domínios cobrados, as dicas de prova mais importantes e 10 questões comentadas para treinar.

540	6	83%
questões no curso	provas completas	nota de corte

Como é a prova CompTIA Security+ SY0-801



Material independente de preparação, sem afiliação ou endosso de CompTIA. As questões são inéditas e não reproduzem a prova real.

Pronto para o exame CompTIA Security+ SY0-801?

Treine com as 540 questões em 6 provas completas: tempo do exame, explicação de cada alternativa e link da documentação para revisar.

Ver as 6 provas completas e o cupom do mês →

Dicas de prova por domínio

Gestão e Supervisão do Programa de Segurança

- Fornecedor em outro país e leis diferentes: limitação de jurisdição.
- Escopo, limites e contatos do pentest: regras de engajamento.
- Documento que dá autoridade e escopo à auditoria interna: audit charter.
- Compromisso, definições e papéis aprovados pela diretoria: política de resposta a incidentes.
- Quem decide e responde pelo tratamento do risco: risk owner.
- Processos críticos e impacto da parada antes do plano de continuidade: BIA.
- Documento, senha e crachá largados na mesa: política de mesa limpa.
- Modelo pronto e testado para desenhar a solução: arquitetura de referência.

Operações de Segurança

- Proteger só os dados da empresa no celular pessoal: proteção de aplicativos (MAM).
- NIST atual: senha longa, sem regra de composição, sem expiração periódica e com checagem de vazadas.
- Contato e tratativas com os criminosos durante o incidente: negociação.
- Chave de nuvem barrada antes do envio ao repositório: secrets scanning com push protection.
- Página de aceite ou login antes de navegar no Wi-Fi: portal cativo.
- Porta só abre depois de autenticar no RADIUS: 802.1X.
- Executar o suspeito em ambiente isolado antes de liberar: sandbox.
- Medo de ficar trancado fora do locatário: contas de emergência (break glass) monitoradas.

Conceitos Gerais de Segurança

- Impede o acesso antes que aconteça: preventivo, seja físico ou técnico.
- Quem fez, o quê, quando e de onde: accounting.
- Procedimento executado por pessoas no dia a dia: controle operacional.
- Chave privada vazou: revogue e emita com chaves novas.
- Sistema legado sem suporte na mudança: testar antes em ambiente espelho e ter backout.
- Quem decide: PDP. Quem aplica no caminho do tráfego: PEP.
- Site público sem alerta no navegador: certificado de AC pública, não autoassinado.
- Período em que o sistema fica fora do ar durante a mudança: downtime.

Arquitetura de Segurança

- Muitos clientes na mesma infraestrutura do provedor: nuvem pública.
- Separar redes no mesmo switch: VLAN (segmentação lógica).
- Mudou de área e levou os acessos antigos junto: privilege creep.
- Dado restrito definindo onde o sistema pode morar: classificação dos dados.
- Crescer nos picos e encolher depois: escalabilidade.
- Saúde e genética na LGPD: dado pessoal sensível.
- Dano grave: secreto. Excepcionalmente grave: ultrassecreto.
- MTTR = horas de reparo ÷ número de falhas.

Ameaças, Vulnerabilidades e Ataques

- IA devolvendo dado real de outra pessoa: perda de dados pela saída.
- Espalha sozinho pela rede, sem clique: worm.
- Governo estrangeiro tentando mudar a opinião do eleitorado: Estado com motivação de influência.
- Mensagem de erro diferente para conta existente: enumeração de usuários.
- Bucket aberto para leitura sem autenticação: armazenamento de objetos público.
- Provedor de nuvem invadido expõe os dados de vários clientes: vetor SaaS.
- Fabricante não corrige mais: produto sem suporte.
- E-mail sob medida para um funcionário: spear phishing. Para o alto escalão: whaling.

10 questões para treinar

Responda antes de olhar o gabarito, no fim do material.

Questão 1 · Conceitos Gerais de Segurança

Na Cooperativa Café do Vale, a analista de folha de pagamento recebeu permissão de leitura e escrita em todas as pastas do servidor de arquivos, para não precisar pedir acesso quando surgisse uma demanda. Qual princípio de segurança essa concessão viola?

A. Defesa em profundidade
B. Separação de funções
C. Não repúdio das ações
D. Menor privilégio

Questão 2 · Conceitos Gerais de Segurança

Um analista da Rede Hoteleira Mar Azul quer alterar regras do firewall principal em produção. A política de gestão de mudanças exige que a solicitação, com análise de impacto e plano de reversão, seja avaliada antes por um grupo com representantes de TI, segurança e áreas de negócio. Que grupo é esse?

A. Comitê consultivo de mudanças (CAB)
B. Centro de operações de segurança (SOC)
C. Comitê de auditoria do conselho
D. Equipe de resposta a incidentes (CSIRT)

Questão 3 · Operações de Segurança

O EDR da Agência Criativa Pixel detectou ransomware começando a cifrar arquivos em um notebook. Antes de qualquer análise, o SOC usou o console para cortar todas as conexões de rede do equipamento, exceto a comunicação com o próprio EDR. Que ação de resposta a incidentes é essa?

A. Erradicação por reinstalação completa do sistema
B. Lições aprendidas com a diretoria
C. Recuperação a partir do backup
D. Contenção por isolamento do dispositivo

Questão 4 · Conceitos Gerais de Segurança

O administrador da Editora Pinheiral vai obter de uma autoridade certificadora pública um certificado TLS para o portal do cliente. Ele gera o par de chaves no próprio servidor e cria a solicitação de assinatura (CSR). O que deve ir na CSR enviada à AC?

A. O certificado raiz da AC e a chave privada do servidor
B. A chave pública e os dados que identificam o servidor
C. A chave privada cifrada com a senha do administrador
D. A chave privada e os dados de identificação do servidor

Questão 5 · Operações de Segurança

No SOC da Rede de Varejo Estrela, cada alerta crítico do SIEM passou a abrir automaticamente um chamado na ferramenta de ITSM, já preenchido com host, usuário e IoCs, atribuído à fila certa e com prazo conforme a severidade. Que caso de uso de automação é esse?

A. Gerenciamento de estado desejado
B. Gerenciamento automatizado de tickets
C. Provisionamento automático de recursos de nuvem
D. Detecção de anomalias por IA

Questão 6 · Conceitos Gerais de Segurança

A equipe do ERP da Distribuidora Ventos do Sul vai atualizar o banco de dados em uma janela noturna. O CAB só aprova a mudança se houver um caminho documentado para restaurar a versão anterior, com backup testado, caso a atualização falhe. O que está sendo exigido?

A. Lista de bloqueio de aplicativos
B. Plano de reversão (backout)
C. Análise de causa raiz
D. Relatório pós-incidente

Questão 7 · Operações de Segurança

Antes de comprar 300 switches, a Prefeitura de Campo Verde quer reduzir o risco de receber equipamentos falsificados ou adulterados. Qual prática do processo de aquisição é a mais adequada?

A. Comprar de canais autorizados e conferir a integridade
B. Escolher o menor preço em marketplaces abertos
C. Dispensar o inventário dos switches recebidos
D. Instalar os equipamentos antes de conferir a nota fiscal

Questão 8 · Operações de Segurança

Uma varredura de segredos executada pela primeira vez nos repositórios da Software House Código Limpo encontrou uma chave de acesso de nuvem válida em um commit de dois anos atrás, já removida do código atual. Qual é a ação correta?

A. Revogar e rotacionar a chave e verificar seu uso
B. Tornar o repositório público para auditoria
C. Manter a chave, pois já saiu da versão atual do código
D. Apagar o commit e manter a mesma chave ativa

Questão 9 · Conceitos Gerais de Segurança

Uma atualização de configuração do serviço DNS interno da Universidade Lago Sul exigirá reiniciar o serviço; por alguns segundos as consultas falharão, afetando autenticação, e-mail e acesso a sistemas. O que a gestão de mudanças deve prever?

A. Desligamento dos serviços que dependem do DNS
B. Reinício imediato em horário de pico, sem comunicação
C. Cancelamento da mudança até haver novo servidor
D. Reinício na janela, com redundância ou aviso aos afetados

Questão 10 · Operações de Segurança

Depois de um incidente, a Mineradora Vale Fundo não conseguiu dizer quantos notebooks tinha, quem os usava nem onde estavam. A direção quer um processo contínuo para registrar cada ativo, seu responsável e sua localização ao longo da vida útil. Que atividade de gestão de ativos foi negligenciada?

A. Teste de restauração de backups
B. Sanitização de mídias no descarte
C. Inventário e rastreamento de ativos
D. Classificação de dados sensíveis

Gabarito comentado

1. D) Menor privilégio
Acesso além do necessário para a função: viola o menor privilégio.

2. A) Comitê consultivo de mudanças (CAB)
Grupo que aprova mudanças antes da execução: CAB.

3. D) Contenção por isolamento do dispositivo
Cortar a rede do equipamento infectado: contenção por isolamento.

4. B) A chave pública e os dados que identificam o servidor
CSR = chave pública + identidade; chave privada fica em casa.

5. B) Gerenciamento automatizado de tickets
Alerta virando chamado preenchido e encaminhado sozinho: gestão automatizada de tickets.

6. B) Plano de reversão (backout)
Como desfazer se der errado: plano de backout.

7. A) Comprar de canais autorizados e conferir a integridade
Compra segura: canal autorizado e verificação na entrega.

8. A) Revogar e rotacionar a chave e verificar seu uso
Segredo encontrado no histórico: revogue e rotacione, não basta apagar.

9. D) Reinício na janela, com redundância ou aviso aos afetados
Reiniciar serviço do qual muitos dependem: janela, redundância e aviso.

10. C) Inventário e rastreamento de ativos
Não sabe o que tem, com quem está e onde: falta inventário e rastreamento.

Pronto para o exame CompTIA Security+ SY0-801?

Treine com as 540 questões em 6 provas completas: tempo do exame, explicação de cada alternativa e link da documentação para revisar.

Ver as 6 provas completas e o cupom do mês →